CRA-related standards

Status from 11 November

OpenSSF

OPEN SOURCE SECURITY FOUNDATION

Copyright © 2024 The Linux Foundation®. All rights reserved. The Linux Foundation has registered trademarks and uses trademarks.

Introduction

CRA Standardization request

EUROPEAN
COMMISSION

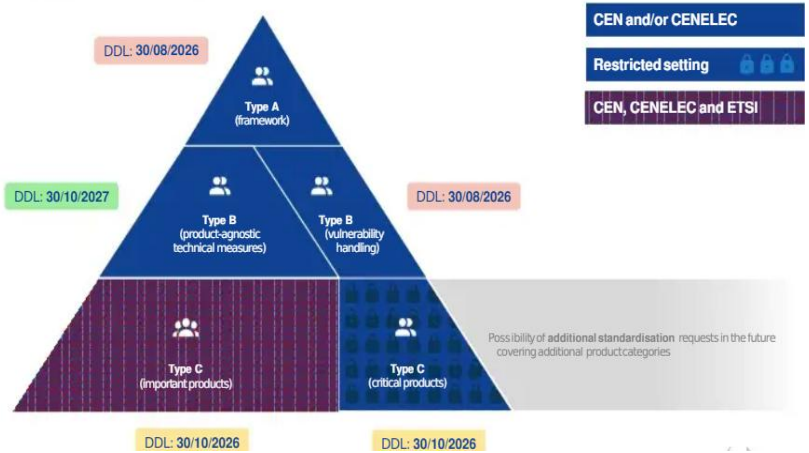
Brussels, 3.2.2025
C(2025) 618 final

COMMISSION IMPLEMENTING DECISION

of 3.2.2025

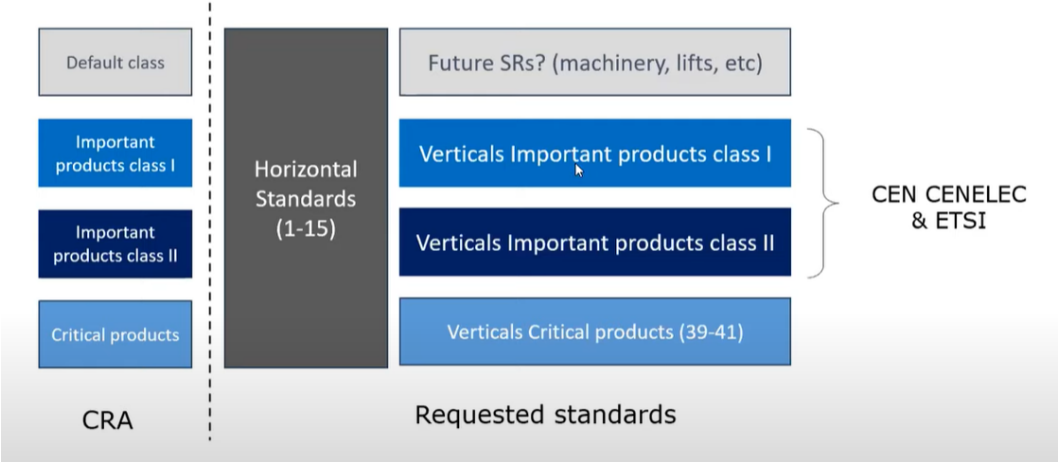
on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)

https://ec.europa.eu/transparency/documents-register/detail?ref=C(2025)618&lang=en
https://cyberstand.eu/sites/default/files/2025-02/Filipe%20Slides%20CRA_implementation_Feb-2025.pdf



Horizontal standards (1-15)	Vertical standards (16-41)
• Risk-based approach (CRA Annex I) • Essential Requirements (CRA Annex I part 1) • Vulnerability Handling (CRA Annex I part 2)	• Important products class 1 (CRA Annex III) • Important products class 2 (CRA Annex III) • Critical products (CRA Annex IV)

CRA Standardization request

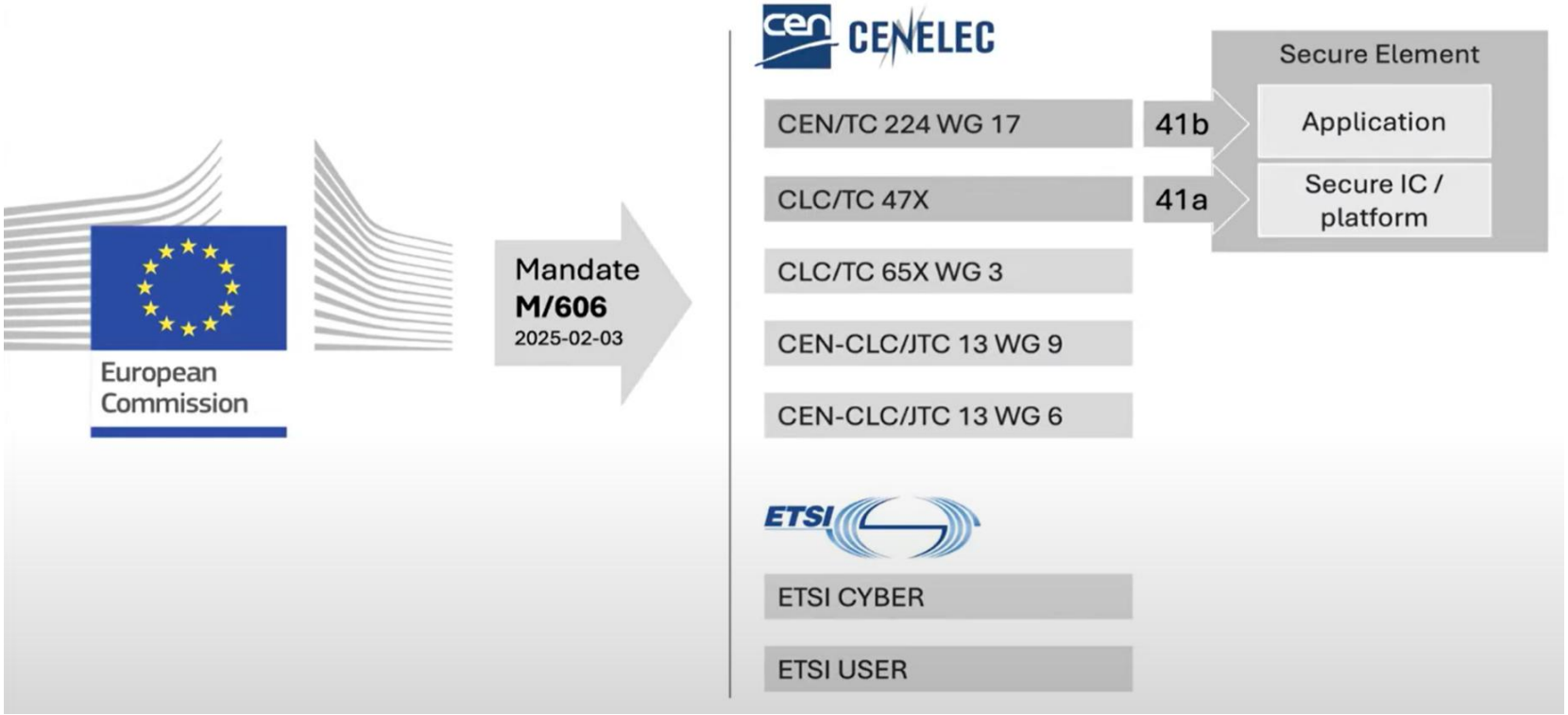


41 topics

3 ‘types’ of deliverables:

Category “A”: horizontal framework	Category “B”: product-agnostic technical measures & vulnerability handling	Category “C”: Important and critical products CRA Standardization Request 9 April 2025 36
• Only CEN and CENELEC • Topic #1 (JTC 13 WG9) • deadline 2026-08-30	• Only CEN and CENELEC • Topic #2-15 (JTC 13 WG9) • Deadline 2027-10-30 (except for line 15 - vulnerability handling - 2026-08-30)	• Topic #16-38: CEN, CENELEC and ETSI • deadline 2026-10-30 • Topic #39-41:CEN and CENELEC • Critical products

CRA Standardization request



https://www.youtube.com/watch?v=_C9HGqBT6qw

A section of the CEN, CENELEC and ETSI WP

Version: V1
Date: 2025-04-02

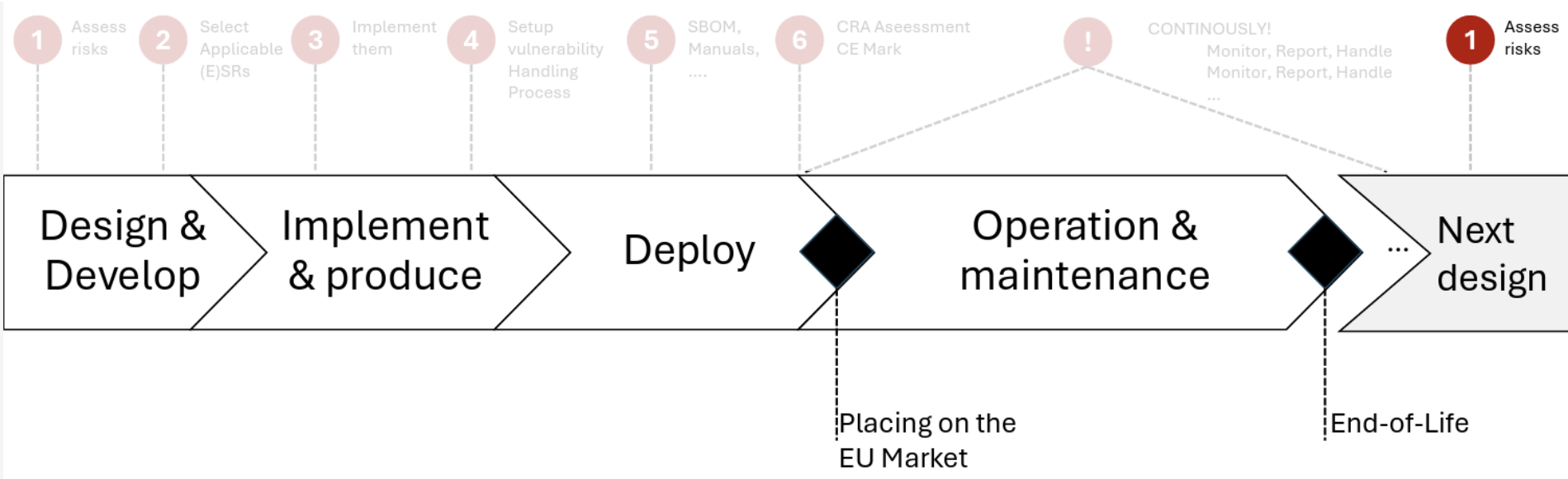
CEN, CENELEC and ETSI Work Programme
M/604- Cyber Resilience Act

M/606	Technical Committee(s)		M/606 - Planning for standard development						
Topics M606 - Annex I	TC ref.	TC title	In collaboration with	Work Item	Standard reference	Standard title	Last realized stage	Deadline for adoption	Comment
Line 1: European standard(s) on designing, developing and producing products with digital elements in such a way that they ensure an appropriate level of cybersecurity based on the risks									
1	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013089	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements Principles for cyber resilience	10.99 - NWI - New Work Item adopted	2026/08/30	
Lines 2-14 - European standard(s) CRA essential requirements									
2 to 14	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013091	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements – Generic Security Requirements	10.99 - NWI - New Work Item adopted	2027/10/30	
Line 15: European standard(s) on vulnerability handling for products with digital elements									
15	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013090	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements – Vulnerability handling	10.99 - NWI - New Work Item adopted	2026/08/30	
Line 16: European standard(s) on essential cybersecurity requirements for identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers									
16	CEN/TC 224 WG 17	Personal identification and related personal devices with secure element, systems, operations and privacy in a multi sectorial environment	CEN/TC 224 WG 17 (including expertise from WG 18,19 and 20) TC ESI	002242XX	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers : criteria to fulfill with the essential requirements from regulation 2024/2487 (CRA)	TC decision taken	2026/10/30	
Line 17: European standard(s) on essential cybersecurity requirements for standalone and embedded browsers									
17a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 617-1*	European standard(s) on essential cybersecurity requirements for embedded browsers	PWI - Proposed Work Item created	2026/10/30	
17b	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 617-2*	European standard(s) on essential cybersecurity requirements for standalone browsers	PWI - Proposed Work Item created	2026/10/30	
Line 18: European standard(s) on essential cybersecurity requirements for password managers									
18	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 618*	European standard(s) on essential cybersecurity requirements for password managers	PWI - Proposed Work Item created	2026/10/30	
Line 19: European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software									
19	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 619*	European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software	PWI - Proposed Work Item created	2026/10/30	
Line 20: European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)									
20a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9 CLC/TC 65X WG3 mode 2	*(Will be be defined after the adoption of the Work Item)*	*EN 304 620*	European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)	PWI - Proposed Work Item created	2026/10/30	
20b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	ETSI TC Cyber EUSR Mode 2	81652	*EN 62443-5-XX (Will be be defined after the activation of the Work Item)*	Security Profile for products with digital elements with the function of virtual private network (VPN)	00.60 - PWI - Preliminary Work Item created	2026/10/30	
Line 21: European standard(s) on essential cybersecurity requirements for network management systems									
21a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9 CLC/TC 65X WG3 mode 2	*(Will be be defined after the adoption of the Work Item)*	*EN 304 621*	European standard(s) on essential cybersecurity requirements for network management systems	PWI - Proposed Work Item created	2026/10/30	
21b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	ETSI TC Cyber EUSR Mode 2	81650	*EN 62443-5-XX (Will be be defined after the activation of the Work Item)*	Security Profile for network management systems (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30	

Not complete

https://www.cencenelec.eu/media/CEN-CENELEC/News/Newsletters/2025/m_606_work_programme_final.pdf

CRA compliance and Product life cycle



Standards developed under CEN/CENELEC

CEN/CENELEC Work Programme

Project Team 1	Project team 2	Project team 3

• **Cybersecurity requirements for products with digital elements – Principles for cyber resilience**
• WI number – JT013089
• CRA requirement Annex I, Part I, 1
• M/606 item 1, 30/08/2026
• Does not (directly) provide a presumption of conformity.
• Addressing the process activities for security risk management during the total product life cycle.
• Activities are described as:
  • Expected inputs
  • Requirement
  • Expected outputs
  • Assessment criteria
• As a horizontal framework standard, it will not mandate any specific methodologies.
	• **Cybersecurity requirements for products with digital elements – Generic security requirements**
	• WI number : JT013091
	• CRA requirement Annex I, Part I, 2
	• M/606 items 2-14, 30/10/2027
	• Does not provide a presumption of conformity.
	• Addressing the essential product requirements.
	• Provides a library of security controls with their objectives and more technical assessment criteria.
	• Provides a mapping of the essential requirements to these security controls.
	• Builds upon the EN 18031:2024 series, augmented with additional security controls.
		• **Cybersecurity requirements for products with digital elements – Vulnerability handling**
		• WI number : JT013090
		• CRA requirement Annex I, Part II
		• M/606 item 15, 30/08/2026
		• The only horizontal standard of the three that hopefully might be suited for citation to provide a partial presumption of conformity.
		• Addressing the process activities for vulnerability handling.
		• Perceived as a horizontal standard that the verticals should be able to normatively reference with no or minimal adoptions.
		• Strong normative dependency on the SOTA standards EN ISO/IEC 30111 and 29147.

CEN/CENELEC JTC 13 WG9 Work Programme

Project 1

High level process **activities** to address the Total Product Life Cycle, defining:

- Goal that needs to be achieved
- Mandatory and optional inputs
- Minimum expected outcomes

Process activities such as security monitoring, risk assessment, verification, validation and release

Project 3

More detailed process **activities** (with assessment criteria fit for a presumption of conformity) to address the vulnerability management requirements

During risk assessment the appropriate security controls and their appropriate level can be selected to ensure risks are mitigated to an acceptable level

Risk assessment

Product requirements

Project 2

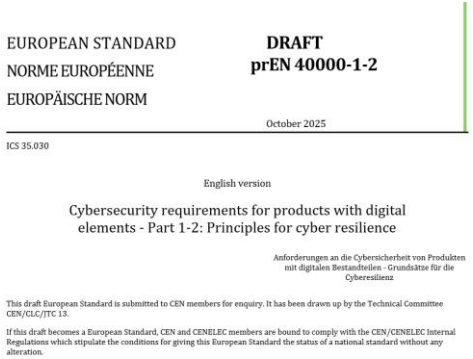
A mapping of the essential product requirements to a list of appropriate **security controls** at various levels

(controls have their own scale/levels to achieve the goal of the security control)

During the elicit requirements activity the deliverables from project 2 can be used to determine and select the appropriate security controls that should be implemented into the product to fulfil on a risk-based manor the essential requirements

PT1 and Vocabulary are under NSB ENQ

- prEN 40000-1-2 = PT1 = Part 1-2: Principles for cyber resilience https://komport.evs.ee/Default.aspx?s=standardCommenting&doc=19694
- prEN 40000-1-1 = Vocabulary https://komport.evs.ee/Default.aspx?s=standardCommenting&doc=19689
- They are also available:
  - on NBN site (National Belgium Standardization Body):
    - PT1
    - Vocabulary
  - on BSI website (UK National Standardization Body):
    - Vocabulary
    - PT1
  - Please note that both the BSI and NBN platforms require an account even to view the documents.
- HAS reviewed the PT1 – 35 pages of comments



EUROPEAN STANDARD
NORME EUROPÉENNE
EUROPÄISCHE NORM

DRAFT
prEN 40000-1-2

October 2025

ICS 35.030

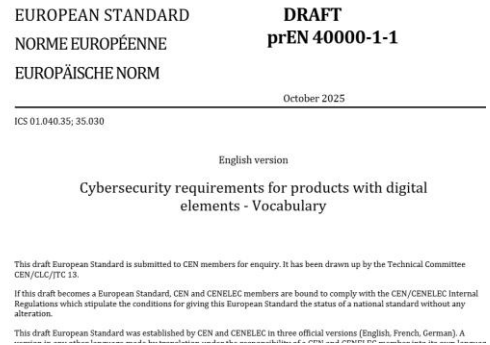
English version

Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience

Anforderungen an die Cybersicherheit von Produkten mit digitalen Bestandteilen - Grundsätze für die Cyberesilienz

This draft European Standard is submitted to CEN members for enquiry. It has been drawn up by the Technical Committee CEN/CLC/JTC 13.

If this draft becomes a European Standard, CEN and CENELEC members are bound to comply with the CEN/CENELEC Internal Regulations which stipulate the conditions for giving this European Standard the status of a national standard without any alteration.



EUROPEAN STANDARD
NORME EUROPÉENNE
EUROPÄISCHE NORM

DRAFT
prEN 40000-1-1

October 2025

ICS 01.040.35; 35.030

English version

Cybersecurity requirements for products with digital elements - Vocabulary

This draft European Standard is submitted to CEN members for enquiry. It has been drawn up by the Technical Committee CEN/CLC/JTC 13.

If this draft becomes a European Standard, CEN and CENELEC members are bound to comply with the CEN/CENELEC Internal Regulations which stipulate the conditions for giving this European Standard the status of a national standard without any alteration.

This draft European Standard was established by CEN and CENELEC in three official versions (English, French, German). A

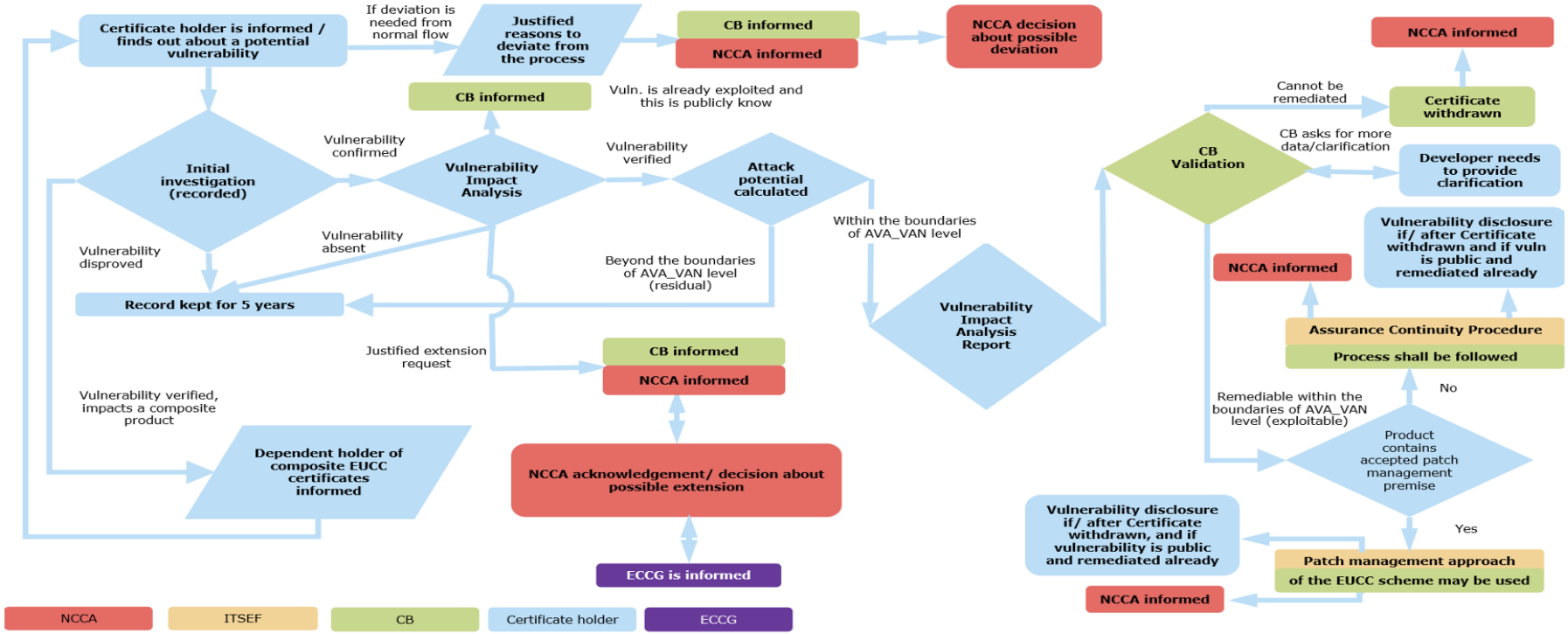
PT2

- Still paused
- It’s the only horizontal one that will be delivered in 2027

PT3

- Delayed
- Planned to start the public inquiry on 27 November
- Main barrier – the HAS consultants comments (66 pages of comments and replies)
  - Not addressing the EC's requests, which may go beyond what can reasonably be achieved by consensus, could reduce the chances of PT3 being cited for presumption of conformity
  - For example:
    - products and for the vulnerabilities with higher-risk
      - CRA does not provide such classification
        - The EC's FAQs and CEN/CENELEC do not have interpretative or normative authority under EU law and therefore cannot establish such classifications.
        - Any change to product classification or risk differentiation must be made through a legislative or implementing act, not via informal guidance or standards.
      - SBOMs shall be drawn completely for those products
        - Their minimum list of elements to identify a product should include other elements also
      - Majority of organizations are against introducing that classifications
      - DG GROW confirmed that the responsibility for the risk level lies with the manufacturers
    - Multiple processes for vulnerability handling depending on whether the product is low, medium or high risk and the vulnerability is low, medium or high risk
    - It was requested to consider GCVE-BCP-02 - Practical Guide to Vulnerability Handling and Disclosure https://gcve.eu/bcp/gcve-bcp-02/
      - New initiative developed by CIRCL
      - Not a recognized organization such as NIST, FIRST or OWASP
    - Reporting using the CSAF standardized format

EUCC SCHEME GUIDELINES ON VULNERABILITY MANAGEMENT AND DISCLOSURE



Costs of the standards

- ETSI – theoretically free
- CEN
  - For example, PT3
    - Cost of a CEN Standard – 150-200 euro
    - ISO/IEC 29147:2018 – 155 CHF
    - ISO/IEC 30111:2019 – 98 CHF
    - PT1 – 150-200 euro
    - PT2 – 150-200 euro
    - IEC 62443-4-1:2018 – 320 CHF
    - ISO/IEC TR 5895:2022 – 98 CHF
    - Vocabulary – I hope that will be free
    - EN 301549 v3.2.1 - free
    - prEN IEC 61360-7:2025 – 40 CHF
    - ISO/IEC 5962:2021 – SPDX – free
    - ISO 8601-1:2019 – 177 CHF
    - Further definitions: ISO/IEC 29119-2:2021, ISO 28001:2007, ISO/IEC/IEEE 24765:2017, ISO 31073:2022

~1500 euro

Cheaper solutions may be available at the level of NSBs

- *"Sharing or posting the ISO publication(s) on your company's intranet is not permitted under this Licence Agreement"*
- "If you have ordered (an) ISO publication(s) in paper form, you may not photocopy or reproduce it/them in any way. Additional paper copies may only be made with written permission from ISO or your ISO Member."

Standards developed under ETSI

ETSI Work Programme

18 WIs, Work in progress, displaying 1 to 18				Displays
Work item number	Version	Current status	Next status	Rapporteur name
CYBER EUSR				
DEN/CYBER-EUS-0010 (EN 304 622) CRA SIEM systemsTopic # 22 Part 1/2	0.0.4	Final deliverable registered for formal adoption (2025-11-10)	Final deliverable voting initiated	Toikka Santeri
DEN/CYBER-EUS-0011 (EN 304 631) CRA Smart home assistants Topic # 31 full	0.0.3	Early draft (2025-11-05)	Stable draft	Mitterweger Kilian
DEN/CYBER-EUS-0012 (EN 304 626) CRA operating systemsTopic # 26 Part 1/N	0.0.9	Stable draft (2025-11-03)	Mature draft	Black Aeva
DEN/CYBER-EUS-0013 (EN 304 627) CRA routers, modems, and switches Topic # 27 Part 1/2	0.0.8	Stable draft (2025-10-25)	Mature draft	Banelli Bruno
DEN/CYBER-EUS-0014 (EN 304 632) CRA Smart home security products Topic # 32 full	0.0.3	Early draft (2025-11-05)	Stable draft	Mitterweger Kilian
DEN/CYBER-EUS-0015 (EN 304 624) CRA PKI and digital certificate issuance software - Topic #24	0.0.5	Early draft (2025-10-30)	Stable draft	Haddad Sammy
DEN/CYBER-EUS-0016 (EN 304 635) Essential cybersec reqts for hypervisors and container runtime systems	0.0.8	Stable draft (2025-11-09)	Mature draft	Hajj Mohamad
DEN/CYBER-EUS-0017 (EN 304 625) Essential cybersec reqts for physical and virtual network interfaces	0.0.9	Stable draft (2025-11-05)	Mature draft	Aurora Valerie
DEN/CYBER-EUS-0018 (EN 304 619) CRA antivirus software Topic # 19 full	0.0.7	Stable draft (2025-10-31)	Mature draft	Alemany Pol
DEN/CYBER-EUS-0019 (EN 304 642) Cybersecurity reqts for Network functions of Telecoms systems	0.0.4	Early draft (2025-11-05)	Stable draft	Sahlin Bengt
DEN/CYBER-EUS-0020 (EN 304 636) Essential cybersec reqts for firewalls, intrusion detection and prevention systems	0.0.6	Final deliverable registered for formal adoption (2025-11-10)	Final deliverable voting initiated	Samardzic Damir
DEN/CYBER-EUS-003 (EN 304 634) CRA Personal wearables Topic # 34 full scope	0.0.2	Early draft (2025-09-30)	Stable draft	Pratone Davide
DEN/CYBER-EUS-004 (EN 304 633) CRA Internet connected toys Topic # 33 full scope	0.0.3	Early draft (2025-11-05)	Stable draft	Meister Gisela
DEN/CYBER-EUS-005 (EN 304 620) CRA VPNs Topic # 20 Part 1/2	0.0.13	Early draft (2025-11-02)	Stable draft	Braun Aki
DEN/CYBER-EUS-006 (EN 304 617) CRA essential cyber reqts for browsers Topic # 17	0.0.6	Stable draft (2025-11-03)	Mature draft	Thompson-Yvetot Daniel
DEN/CYBER-EUS-007 (EN 304 618) CRA password managers Topic # 18 full	0.0.3	Final deliverable registered for formal (2025-11-10)	Final deliverable voting initiated	Thompson-Yvetot Daniel
DEN/CYBER-EUS-008 (EN 304 623) CRA boot managersTopic # 23 Full	0.0.8	Early draft (2025-11-06)	Stable draft	Horchert Christian
DEN/CYBER-EUS-009 (EN 304 621) CRA Network Management Topic # 21	0.0.6	Early draft (2025-10-22)	Stable draft	Toikka Santeri

Key information

- https://portal.etsi.org/home.aspx
- All the works are under the control of TC CYBER WG EUSR https://portal.etsi.org/tb.aspx?tbid=919&SubTB=919#/
- The work programme and the meeting schedule can be found navigating on that page
  - Very intense meeting schedule
  - They have monthly joint meetings with CEN and CENELEC
  - They have weekly general syncs
- Their Forge https://forge.etsi.org/rep/cyber/stan4cr2
  - Only 10 standards (among 18) are developed using markdown
  - The links are also displayed on the WI page
- Links for Public Consultation on ETSI standards
  - https://docbox.etsi.org/CYBER/EUSR/Open
  - https://labs.etsi.org/rep/stan4cra/

ETSI Public Consultation

- Previewed by a webinar on 29 September
- From late October onwards
  - **Piloting their public consultation at the end of September**
    - https://docbox.etsi.org/CYBER/EUSR/Open
    - https://labs.etsi.org/rep/stan4cra/
    - Pilot standards: Routers, Hypervisors, OS, NI, Boot Managers, Password Managers and Firewalls
    - Everyone will have access to those standards for submitting comments
  - In collaboration with CEN/CENELEC
    - Further details will be provided on Stan4CRA website or ETSI website
      - Specific formal commenting and feedback window
      - Option to comment via ETSI Labs or traditional commenting table
      - Drafts will be available on both ETSI labs and CYBER open portal area
- Standards will be ultimately approved by NSBs
  - Another opportunity to comment via NSB national commenting

ETSI Public Consultation

- Instructions for submitting feedback can be found in the readme.md files available with every standard.
  There are two official submission options:
  - Directly in the .md file or related to the .pdf files from the labs.etsi.org repositories.
  - Via an Excel template available on docbox.etsi.org.
- Important detail: I heard during the last WG CYBER EUSR meeting that a deep-dive session will be held to resolve the public comments, and *only those who officially submit comments/feedback will be invited.*
- Therefore, my strong suggestion is to submit your feedback using one of the two official ETSI options listed above.
- For our internal WG consultation:
  - we have also put the available .md files into a shared Google Drive for your convenience to enable a preliminary discussion at our WG level: https://drive.google.com/drive/folders/1kg-U9KmgdjQjtC8OigdwJpwGBlBx_lHv?usp=sharing
  - We remain fully available to discuss any doubts, topics, or unclarities you may have related to these standards.
  - We will reserve time during the Standardization SIG meetings and can schedule additional meetings as needed.
- All the standards have been updated
  - You will find there the pdfs, the instructions for submitting the comments and also the Gdocs (trying to get closer to the original .md files)
  - I also added a new Template for comments

Interplay with other regulations/standards – PKI case

- A PKI certified against
  - The cybersecurity requirements of NIS2 CIR 2024/2690
  - Based on a bi-annual audit as specified in EN 319401
  - In line with EN 319403-1 conformity assessment
  - Applying an identified certificate policy
  - ➔ Meets CRA requirements
  - ➔ Limiting the scope of PKI Vertical
    - ➔ Regulation (EU) 2024/2690 under the NIS2 Directive applies to managed security service providers using PKI techniques.
    - ➔ Software components compliant with standardized PKI certificate policies aligned with this regulation are considered to meet CRA requirements

- references to standards supporting other EU legislation are possible, but they must remain within the CRA's scope
- PKI systems must still demonstrate compliance with the CRA, regardless of NIS2 compliance;
- Overlaps should be clearly identified and justified,
- Reducing scope would hinder manufacturers' ability to prove conformity and should be avoided.

Complementary standards and frameworks

CEN JTC13 WG3 EN18037-2:2026

- Methodology for risk and cybersecurity assessments of sectoral multi-stakeholder systems
- Another framework that may become applicable for risk & cybersecurity assessments
- ENISA report on risk management standards https://www.enisa.europa.eu/sites/default/files/publications/O.7.2-T2-Risk_Management_standards.pdf
  - ISO/IEC 27005 – Information security risk management
  - ISO 31000 – Risk management guidelines
  - BSI 7799-3 – Guidelines for information security risk management
  - NIST SP 800-39 – Managing Information Security Risk
  - BSI Germany Standard 200-3 – Risk analysis based on IT-Grundschutz
- Other examples:
  - ETSI CYBER TR 104117

SSDIF

- CIS and SAFECode have released the Guide for Secure by Design - assessing software security practices

➔ Transposed into ETSI TS 104219

- Software Security Development and Implementation Framework (SSDIF)
- SSDIF Essentials
  - Secure software design
  - Secure development
  - Secure default configuration
  - Supply chain security
  - Code integrity
  - Vulnerability Disclosure and Remediation

Proposal to map EUCRApr to NIST SSDF

- https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-218.pdf
- Proposal from Ericsson in CEN/CLC WG9
- Practices
  - Define Security Requirements for Software Development
  - Implement Roles and Responsibilities
  - Implement Supporting Toolchains
  - Define and Use Criteria for Software Security Checks
  - Implement and Maintain Secure Environments for Software Development
  - Protect All Forms of Code from Unauthorized Access and Tampering
  - Provide a Mechanism for Verifying Software Release Integrity
  - Archive and Protect Each Software Release
  - Design Software to Meet Security Requirements and Mitigate Security Risks
  - Review the Software Design to Verify Compliance with Security Requirements and Risk Information
  - Reuse Existing, Well-Secured Software When Feasible Instead of Duplicating Functionality
  - Create Source Code by Adhering to Secure Coding Practices
  - Configure the Compilation, Interpreter, and Build Processes to Improve Executable Security
  - Review and/or Analyze Human-Readable Code to Identify Vulnerabilities and Verify Compliance with Security Requirements
  - Test Executable Code to Identify Vulnerabilities and Verify Compliance with Security Requirements
  - Configure Software to Have Secure Settings by Default
  - Identify and Confirm Vulnerabilities on an Ongoing Basis
  - Assess, Prioritize, and Remediate Vulnerabilities
  - Analyze Vulnerabilities to Identify Their Root Causes

  - Tasks
  - Notional implementation Examples

Practices	Tasks	Notional Implementation Examples	References
Provide a Mechanism for Verifying Software Release Integrity (PS.2): Help software acquirers ensure that the software they acquire is legitimate and has not been tampered with.	**PS.2.1**: Make software integrity verification information available to software acquirers.	**Example 1**: Post cryptographic hashes for release files on a well-secured website. **Example 2**: Use an established certificate authority for code signing so that consumers' operating systems or other tools and services can confirm the validity of signatures before use. **Example 3**: Periodically review the code signing processes, including certificate renewal, rotation, revocation, and protection.	**BSAFSS**: SM.4, SM.5, SM.6 **BSIMM**: SE2.4 **CNCFSSCP**: Securing Deployments—Verification **EO14028**: 4e(iii), 4e(ix), 4e(x) **IEC62443**: SM-6, SM-8, SUM-4 **NISTCSF**: PR.DS-6 **NISTLABEL**: 2.2.2.4 **OWASPSAMM**: OE3-B **OWASPSCVS**: 4 **PCISSLC**: 6.1, 6.2 **SCSIC**: Vendor Software Delivery Integrity Controls **SP80053**: SA-8 **SP800161**: SA-8 **SP800181**: K0178
Archive and Protect Each Software Release (PS.3): Preserve software releases in order to help identify, analyze, and eliminate vulnerabilities discovered in the software after release.	**PS.3.1**: Securely archive the necessary files and supporting data (e.g., integrity verification information, provenance data) to be retained for each software release.	**Example 1**: Store the release files, associated images, etc. in repositories following the organization's established policy. Allow read-only access to them by necessary personnel and no access by anyone else. **Example 2**: Store and protect release integrity verification information and provenance data, such as by keeping it in a separate location from the release files or by signing the data.	**BSAFSS**: PD.1-5, DE.1-2, IA.2 **CNCFSSCP**: Securing Artefacts—Automation, Controlled Environments, Encryption; Securing Deployments—Verification **EO14028**: 4e(iii), 4e(vi), 4e(ix), 4e(x) **IDASOAR**: 25 **IEC62443**: SM-6, SM-7 **NISTCSF**: PR.IP-4 **OWASPSCVS**: 1, 3.18, 3.19, 6.3 **PCISSLC**: 5.2, 6.1, 6.2 **SCSIC**: Vendor Software Delivery Integrity Controls **SP80053**: SA-10, SA-15, SA-15(11), SR-4 **SP800161**: SA-8, SA-10, SA-15(11), SR-4
	PS.3.2: Collect, safeguard, maintain, and share provenance data for all components of each software release (e.g., in a software bill of materials [SBOM]).	**Example 1**: Make the provenance data available to software acquirers in accordance with the organization's policies, preferably using standards-based formats. **Example 2**: Make the provenance data available to the organization's operations and response teams to aid them in mitigating software vulnerabilities. **Example 3**: Protect the integrity of provenance data, and provide a way for recipients to verify provenance data integrity. **Example 4**: Update the provenance data every time any of the software's components are updated.	**BSAFSS**: SM.2 **BSIMM**: SE3.6 **CNCFSSCP**: Securing Materials—Verification, Automation **EO14028**: 4e(vi), 4e(vii), 4e(ix), 4e(x) **NTIASBOM**: All **OWASPSCVS**: 1.4, 2 **SCSIC**: Vendor Software Delivery Integrity Controls **SCTPC**: MAINTAIN3 **SP80053**: SA-8, SR-3, SR-4 **SP800161**: SA-8, SR-3, SR-4

Events

CfP FOSDEM

- CFP for **FOSDEM CRA In Practice Devroom** is now open!
- Submit here: https://pretalx.fosdem.org/fosdem-2026/cfp
- Instructions: https://lists.fosdem.org/pipermail/fosdem/2025q4/003697.html
- Important Dates:
  - CfP closes: 1st December 2025 (23:59 UTC)
  - Notification of acceptance: mid-December 2025
  - CRA In Practice Devroom at FOSDEM 2026: Saturday, 31st January 2026, Brussels, Belgium
- Let Roman, Madalin, Megan or Philippe know if you have any questions!

- CFP for **Open Source and EU Policy** is now open!
  - More oriented towards the standards and interplay between the laws
- Submit here: https://pretalx.fosdem.org/fosdem-2026/cfp
- Instructions: https://lists.fosdem.org/pipermail/fosdem/2025q4/003697.html
- Important Dates:
  - CfP closes: 1st December 2025 (23:59 UTC)
  - Notification of acceptance: mid-December 2025
  - CRA In Practice Devroom at FOSDEM 2026: Saturday, 31st January 2026, Brussels, Belgium
- Let Madalin know if you have any questions!

AOB

Public consultation to gather your views on revising the EU Standardisation Regulation

- EU launched a public consultation to gather your views on revising the EU Standardisation Regulation.
- This is your opportunity to contribute to a strategic, future-proof approach to standardisation in Europe
- Are you interested in making the European standardisation system faster, more transparent, and open to all, including startups, SMEs and civil society?
- Contribute by 17 December: https://ec.europa.eu/info/law/better-regulation/info/law/better-regulation/have-your-say/initiatives/14511-Standardisation-Regulation-revision_en

Regulation 2025/2162 the accreditation of conformity assessment bodies

- https://webgate.ec.europa.eu/single-market-compliance-space/notified-bodies/notified-body-list?filter=legislationId:164702,notificationStatusId:1
- Here are the EUCC accredited (and where relevant authorised) CABs

Official Journal
of the European Union

EN
L series

2025/2162

28.10.2025

COMMISSION IMPLEMENTING REGULATION (EU) 2025/2162

of 27 October 2025

laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and the Council as regards the accreditation of conformity assessment bodies performing the assessment of qualified trust service providers and the qualified trust services they provide, the conformity assessment report and the conformity assessment scheme

THE EUROPEAN COMMISSION,

Having regard to the Treaty on the Functioning of the European Union,

Having regard to Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC ([1]), and in particular Article 20(4) thereof,

Whereas:

(1) Pursuant to Articles 20(1) and 21(1) of Regulation (EU) No 910/2014, qualified trust service providers and the qualified trust services they provide are to be audited by conformity assessment bodies. The resulting conformity assessment reports confirm whether the requirements laid down in that Regulation and in Article 21 of Directive (EU) 2022/2555 of the European Parliament and of the Council ([2]) are fulfilled. Consequently, it is necessary to establish a harmonised and robust framework for the accreditation of conformity assessment bodies, the conformity assessment schemes they implement, the conformity assessments they perform in accordance with those schemes, and the resulting conformity assessment reports.

(2) The accreditation of conformity assessment bodies assessing qualified trust service providers and the qualified trust services they provide, the conformity assessment report and the conformity assessment scheme should meet the requirements laid down in this Regulation. Conformity assessment bodies may satisfy these requirements either independently, by utilising composite certification or by subcontracting to duly accredited entities.

(3) Conformity assessment bodies accredited for assessing qualified trust service providers and the qualified trust services they provide as regards the issuance of qualified electronic attestations of attributes should be permitted to issue the conformity assessment report required by Article 45f(3) of Regulation (EU) No 910/2014.

(4) To contribute to the transparency of the accreditation process, the accreditation certificate issued to a conformity assessment body in accordance with Article 5 of Regulation (EC) No 765/2008 of the European Parliament and of the Council ([3]), should contain sufficient information to enable third parties to verify that the accredited conformity assessment body is authorised to conduct a conformity assessment under Regulation (EU) No 910/2014.

(5) To maintain the integrity and accuracy of accreditation certificates, national accreditation bodies should ensure that these certificates reflect up-to-date information.

DA for terms & conditions for delaying the notification of incidents

- Deadline 13 November
- Shared document to collect inputs
  https://docs.google.com/document/d/1vckno16oulgPq1UUfjxQrQozQIktglvUrqiTxrCADRQ/edit?tab=t.0
- Comments received until now:
  - Olle: *"We need to somehow have an opinion that the document only mentions manufacturers when Open Source project and stewards also may report."*
    - Will that change anything?
  - Ayoub:
    - "Article 3(a) says mitigation is "expected to be made available within 72 hours" but not whether the clock starts at manufacturer submission or CSIRT acceptance. Is it possible to define a start point (UTC TZ) ? (Ayoub Bourjilat)
      - Are not they the same?
    - Can we explicitly allow lower risk steps and defer higher risk actions (from a safety perspective) for a short or a defined period under Article 3(a/c) ? (Ayoub Bourjilat)
      Example: Motor drive controller (remote write bug) : unauthenticated client can send a parameter write. The normal fix in this case is to suggest an update or a reboot to patch (this will briefly stop the drive, or inconvenient from client perspective) a lower risk solution is to disable remote writes. "
      - are not we referring to a risk mitigation in this context? topic described in the article 3(a)

Thank you very much

OpenSSF
OPEN SOURCE SECURITY FOUNDATION